Role-Based Access Control

Who can do what, and how the server enforces it. **Deny by default:** every API call is checked on the server. The UI only hides buttons you can't use; it is not the security boundary.

1 · Two kinds of role

Global account role (stored on the user, carried in the JWT)

student	Default for every sign-up and Google sign-in.
instructor	Can create courses. Not staff of any course until a member.
admin	Superuser. Acts as instructor on every course; the only one who can change global roles.

Course role (per course membership)

student	Takes quizzes, sees own results, raises appeals.
ta	Drafts content, marks, monitors, investigates.
instructor	All TA rights plus publish, release, delete, roster and rulings.

"TA" exists only inside a course. Whoever creates a course becomes its instructor.

2 · The TA / Instructor line

TA does the work

- Create and edit quiz drafts, questions, slots
- Build question banks, import questions
- Monitor live exams, announce, flag candidates, answer raised hands
- Hand-mark written answers
- Read incidents, attempt timelines, analytics

Instructor makes the decisions

- Publish a quiz; delete a quiz or a whole bank
- Add, remove or promote course members
- Extend time, pause, close or reopen an exam
- Lock / reinstate an attempt, resolve flags
- Regrade, resolve appeals, release results, export grades
- Set student accommodations (extra time)

3 · How every request is checked

1. **Authenticate** (`requireAuth`): valid signed JWT whose session version still matches the account. Revoked or stale → **401**.
2. **Resolve the owner**: the quiz, version, attempt or bank in the URL is looked up to find the course it belongs to. The request body is never trusted for this.
3. **Guard**: `assertMember` , `assertStaff` or `assertInstructor` checks the caller's role in that course. Not allowed → **403**. Global admin passes as instructor.
4. **Audit**: privileged changes (publish, release, rulings, role changes…) are written to an append-only audit log.

Extra checks: exam endpoints (`/api/attempts/:id/*`) require the caller to own the attempt *and* send the attempt's `X-Attempt-Session` token, so only one browser window can drive it. Admin endpoints (`/api/admin/*`) require global role `admin` . Self-registration always creates a student; Google sign-in is verified server-side and limited to `iitrpr.ac.in` .

Where it lives: guards in `apps/api/src/authz.ts` , authentication in `apps/api/src/auth.ts` , one guard call at the top of each handler in `apps/api/src/routes/` . **Tested by:** `rbac.http.test.ts` , `banks.authz.test.ts` , `authz.repro.test.ts` , `results.privacy.test.ts` .

REFERENCE

4 · Permission matrix

✓ allowed · ✗ denied (403) · **own** only on the caller's own data. Course columns mean the caller's role *in that course*; admin needs no membership.

Action	Student	TA	Instructor	Admin
ACCOUNT AND PLATFORM				
Sign up, sign in, Google sign-in	public			
Own profile, accessibility settings, sign out everywhere	✓	✓	✓	✓
Change global roles, revoke sessions, back up DB, read audit log	✗	✗	✗	✓
COURSES				
Create a course (needs global instructor)	✗	✗	✓	✓
Open a course page	✓	✓	✓	✓
See roster and pending enrolments	✗	✓	✓	✓
Add, remove, promote members (last instructor is protected)	✗	✗	✓	✓
QUIZZES AND QUESTION BANKS				
See published quizzes	✓	✓	✓	✓
See drafts; create, edit, copy, restore versions; edit questions and slots	✗	✓	✓	✓
Create banks; add, edit, import, remove bank questions	✗	✓	✓	✓
Publish a quiz	✗	✗	✓	✓
Delete a quiz or a whole bank	✗	✗	✓	✓
RUNNING AN EXAM				
Start and answer an attempt (enrolled, quiz open)	own	own	own	own
Monitor live, announce, flag a candidate, answer raised hands	✗	✓	✓	✓
Extend time, pause / resume, close / reopen	✗	✗	✓	✓
Read incidents and an attempt's full timeline	✗	✓	✓	✓
Rule on an attempt (lock, reinstate, allow submit), resolve flags	✗	✗	✓	✓
See accommodations	own	✓	✓	✓
Set or remove accommodations	✗	✗	✓	✓
GRADING AND RESULTS				
See a result (student: only once the quiz's score setting allows)	own	✓	✓	✓
Analytics, question health, fairness, appeal lists	✗	✓	✓	✓
Hand-mark written answers	✗	✓	✓	✓
Raise an appeal on a mark	own	✗	✗	✗
Regrade a question, normalise a slot, run collusion scan, resolve appeals	✗	✗	✓	✓
Release results, change answer-key visibility, export grades CSV	✗	✗	✓	✓